

Sec-Fetch-Site value	What the value indicates
same-origin	The origin to which the request is being made matches the origin of the code making the request.
same-site	The origin to which the request is being made and the origin of the code making the request have the same "registrable domain" (sometimes also referred to as the "same eTLD+1" or "same effective top-level domain plus one"); so, for example, <code>https://subdomain.example.com</code> and <code>https://example.com</code> are same-site (even though not same-origin).
cross-site	The origin to which the request is being made and the origin of the code making the request are neither same-origin nor even same-site but instead have different registrable domains.
none	The request wasn't initiated programatically by frontend code (for example, not by an XHR/fetch/ajax call) but instead initiated by normal user navigation — that is, by a user doing something like directly putting an address into the browser URL bar, or clicking on a hyperlink.

Table 1: What the sec-fetch-site values indicate

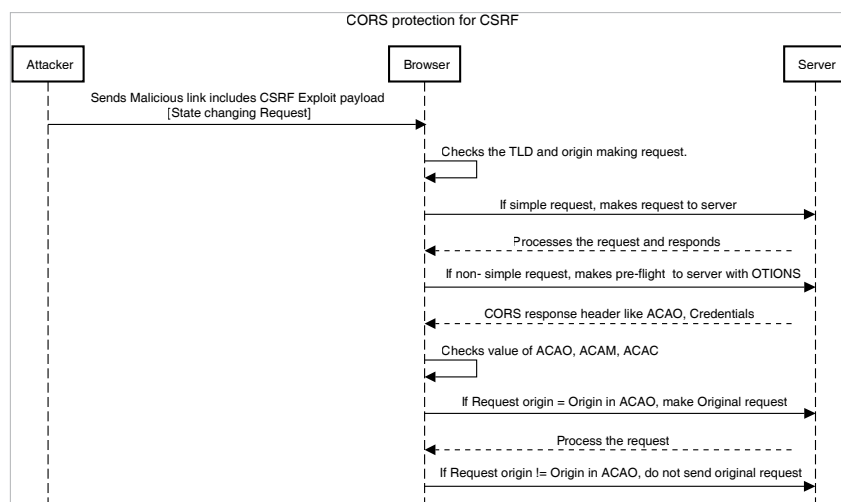


Figure 5: CORS protection for CSRF

Meta headers in the context of CSRF: Modern browsers that support SameSite also make use of additional meta headers in the requests. One such header is 'sec-fetch-site' which browsers use to provide additional information about the type of request (whether it is 'same-origin' or 'same-site'). The meaning of four such possible values is given in Table 1.

Application servers can make use of the meta header for further validation

as protection against CSRF. However, the protection will work only in case of modern browsers that are supporting meta headers. Servers can check for the specific value of 'sec-fetch-site' and process the request accordingly. **END** 🐧

References

- <https://hacktricks.boititech.com.br/pentesting-web/csrf-cross-site-request-forgery>
- <https://web.dev/fetch-metadata/>
- <https://developer.mozilla.org/en-US/docs/Web/HTTP/CORS>
- <https://www.mixmax.com/engineering/modern-csrf>
- <https://w3.ibm.com/w3publisher/security-biso-office/think-like-a-hacker-blog/f67361f0-17ad-11eb-85f4-55670e2b6ea2>

By: Sanjay Phanshikar and Divyasri Thota

Sanjay Phanshikar is an experienced cybersecurity professional at IBM ISL, specialising in the security assessment of products. He is passionate about staying ahead of emerging threats, and leveraging cutting-edge tools and methodologies to protect digital assets and drive robust security initiatives.

Divyasri Thota is a cybersecurity professional at IBM ISL, specialising in application security. Passionate about cybersecurity, she thrives on continuous learning and exploring diverse security domains.